LAPORAN AUDIT VALIDASI & MISS FUNCTION

Project: zafaran-admin (React + TypeScript Admin Dashboard)

Tanggal audit : 08 Oktober 2026
Ruang lingkup : Validasi input form, guard autentikasi/rute, penanganan error, dan fungsi yang hilang atau tidak berfungsi

1. RINGKASAN

46	15	14
Perbaikan diterapkan	File sumber diubah	Titik lolos verifikasi

Audit ini menelusuri celah validasi input dan fungsi yang hilang/tidak berfungsi pada admin dashboard, mencakup lapisan autentikasi dan rute, layanan API, komponen bersama, serta halaman transaksi inti (POS, booking, pelanggan, pengeluaran, setoran bank, user & role, ruangan, dan inventaris).

Seluruh perbaikan pada laporan ini sudah diterapkan langsung ke basis kode dan diverifikasi ulang dengan pemeriksaan TypeScript (tsc -p tsconfig.app.json) tanpa error pada file yang diubah.

2. PERBAIKAN YANG SUDAH DITERAPKAN

A. Autentikasi, Rute & Keamanan Basis Klien

01	**ProtectedRoute hanya mengecek keberadaan localStorage**	App.tsx — nilai apa pun yang tidak kosong (termasuk JSON rusak) dapat membuka seluruh rute admin. Kini payload di-parse, field token divalidasi, nilai rusak dihapus dan dialihkan ke /login.
02	**Rute admin duplikat**	App.tsx — reports/kalkulasi-agenda, pembatalan-agenda, dan detail-agenda dideklarasikan dua kali. Duplikatnya dihapus agar tidak ada rute mati.
03	**Tidak ada rute catch-all**	App.tsx — URL tak dikenal dirender layar kosong. Kini ditambahkan path="*" yang mengarah ke /dashboard (terautentikasi) atau /login.
04	**downloadFile membaca key localStorage yang salah**	api.ts — membaca key "token" yang tidak pernah ditulis, sehingga selalu mengirim "Bearer null" dan gagal 401. Kini memakai getAuthToken().
05	**12 helper FormData membaca token tanpa proteksi**	api.ts — JSON.parse(authData).token tanpa try/catch dapat melempar error di tengah upload. Kini diganti getAuthToken() yang aman.
06	**Respon 401 tidak ditangani pada helper upload/FormData**	api.ts — sesi kedaluwarsa hanya logout di fetchJson. Kini 14 titik memanggil handleUnauthorized() (bersihkan sesi + redirect login).
07	**Status HTTP dibuang saat membangun error**	api.ts — pemanggil tidak bisa membedakan 403/409/422/500. Kini dibuat ApiError yang membawa status dan objek errors.
08	**response.json() tanpa proteksi**	api.ts — body non-JSON (halaman error 502 dari proxy) memunculkan "Unexpected token <". Kini memakai readBody(); fetchWaApi juga melempar Error, bukan objek mentah.
09	**Query string mengirim parameter kosong**	api.ts — buildQueryString menghasilkan "?branch_id=" saat nilai kosong. Kini string kosong ikut difilter.
10	**api.getCustomerVisitHistory tidak pernah didefinisikan**	api.ts — dipanggil dari DaftarPelangganPage sehingga selalu memunculkan TypeError. Kini ditambahkan sebagai alias endpoint history pelanggan.

11 **Logout dapat gagal total**
AdminLayout.tsx — JSON.parse activity_logs dijalankan sebelum sesi dibersihkan; nilai korup membuat tombol logout tidak berfungsi. Kini sesi dibersihkan lebih dulu dan penulisan log dibungkus try/catch.

12 **Ganti cabang dapat melempar error**
AdminLayout.tsx — JSON.parse activity_logs tanpa proteksi di tengah handler. Kini dijaga try/catch.

13 **Header menampilkan "Super Admin" untuk data role kosong**
AdminLayout.tsx — fallback user?.role || "super_admin" menampilkan privisi salah saat data autentik tidak valid. Kini menampilkan role sebenarnya atau "-".

14 **Login tampak gagal padahal berhasil**
LoginPage.tsx — JSON.parse activity_logs dijalankan setelah token tersimpan; nilai korup membuat pesan error muncul dan navigasi batal. Kini dibungkus try/catch.

15 **Dialog konfirmasi auto-CONFIRM saat SweetAlert2 gagal dimuat**
swal.ts — fallback CDN mengembalikan isConfirmed: true sehingga aksi hapus berjalan tanpa persetujuan pengguna. Kini fail-safe ke isConfirmed: false.

16 **HTML injection pada dialog hapus**
swal.ts — nama objek disisipkan mentah ke innerHTML. Kini di-escape dengan escapeHtml().

B. Validasi Input & Anti-Spam Data

17 **Nominal pengeluaran bisa negatif, 0, atau NaN**
ExpensesPage.tsx — hanya cek keberadaan field. Kini divalidasi finite, > 0, dan ada batas atas; deskripsi di-trim sebelum dikirim.

18 **Input nominal pengeluaran tanpa batas**
ExpensesPage.tsx — type="number" tanpa min/step. Kini ditambahkan min={0} step="any" inputMode="decimal".

19 **Filter tanggal terbalik**
ExpensesPage.tsx & BankDepositsPage.tsx — tanggal mulai > tanggal akhir tetap dikirim ke API. Kini ditolak dengan pesan jelas.

20 **Setoran bank negatif/0/NaN lolos validasi**
BankDepositsPage.tsx — satu-satunya cek adalah amount > cashBalance sehingga nilai negatif lolos. Kini divalidasi finite, > 0, batas atas, dan nama bank di-trim.

21 **Saldo cash gagal dimuat membuat semua setoran ditolak**
BankDepositsPage.tsx — pesan "Saldo cash tidak mencukupi: Rp 0" menyesatkan. Kini kekurangan saldo hanya dicek bila saldo valid, dan kegagalan muat saldo diberi notifikasi.

22 **Input setoran & nomor rekening tanpa batas**
BankDepositsPage.tsx — amount tanpa min/step, account_number tanpa panjang maksimum. Keduanya ditambahkan.

23 **Fitur "Tambah Poin" tidak pernah menyimpan data**
CustomersPage.tsx — hanya setTimeout 500 ms lalu menampilkan toast sukses; poin hilang saat reload. Kini memanggil api.adjustCustomerPoints dan menampilkan error jujur bila endpoint belum tersedia.

24 **Input poin tanpa batas**
CustomersPage.tsx — type="number" tanpa min/max/step sehingga poin negatif/pecahan mungkin. Kini dibatasi 1 – 1.000.000 bilangan bulat.

25 **Placeholder "-" memblokir edit pelanggan**
CustomersPage.tsx — email "-" gagal regex sehingga edit tersimpan tidak bisa disimpan; DOB "-" ikut terkirim dan merusak data. Kini "-" dinormalisasi menjadi "" saat membuka dan menyimpan form.

26 **Nama & telepon berisi spasi lolos validasi**
CustomersPage.tsx — " " dianggap terisi. Kini nama/telepon di-trim, nama wajib minimal 2 karakter, telepon wajib terisi.

27 **Sel "Total Spending" mentok "memuat..."**
CustomersPage.tsx — kegagalan request ditelan sehingga loader tidak pernah selesai. Kini diberi status gagal dan dirender "-".

28 **User dapat dibuat tanpa validasi format**
UserManagementPage.tsx — tidak ada cek format email, pola telepon, panjang password, maupun trim nama. Kini ditambahkan regex email, pola 08/+628/021, password minimal 8 karakter, dan nama minimal 2 karakter.

29 **Password tidak dapat diubah saat edit user**
UserManagementPage.tsx — field password disembunyikan pada mode edit sehingga reset password mustahil. Kini field selalu tampil dan bersifat opsional (kosongkan = tidak diubah).

30 **updateRole/deleteRole menghasilkan URL /admin/roles/NaN**
UserManagementPage.tsx — parseInt pada id berbentuk string nama role. Kini divalidasi Number.isInteger dengan pesan yang jelas.

31 **Simpan role berjalan senyap dan role tanpa izin dapat dibuat**
UserManagementPage.tsx — "if (!roleForm.name) return;" tanpa umpan balik. Kini ada toast, nama minimal 3 karakter, wajib minimal satu izin, dan cek nama ganda.

32 **Pembayaran POS dapat dikirim dengan total NaN**
POSPage.tsx — processPayment tidak memvalidasi keranjang, metode, maupun angka. Kini divalidasi: keranjang terisi, metode terpilih, total finite > 0, uang diterima ≥ total (tunai), dan kembalian tidak negatif.

33 **Nominal DP dapat menjadi NaN atau hasil konkatinasi string**
POSPage.tsx — minDP dari localStorage tidak di-coerce sehingga "50000" + 10000 menghasilkan string. Kini di-Number-kan dengan fallback 50000 dan dibulatkan.

34 **Koreksi kas historis tanpa konfirmasi**
POSPage.tsx — handleUpdateShift langsung menimpa saldo akhir shift. Kini ada validasi angka dan dialog konfirmasi swal.

35 **Petty cash dapat bernilai 0 / kategori "undefined"**
POSPage.tsx — handleAddPettyCash return senyap dan category_id jatuh ke string "undefined". Kini setiap kondisi memberi toast, nominal harus > 0, dan kategori wajib dipilih.

36 **Edit pengeluaran dari riwayat tanpa validasi nominal**
POSPage.tsx — nilai kosong/non-angka dikirim apa adanya. Kini divalidasi > 0 dan pesan error asli dari server ditampilkan.

37 **Saldo buka/tutup shift dapat NaN atau negatif**
POSPage.tsx — parseInt(x) || 0 menyembunyikan input tidak valid. Kini divalidasi dengan pesan yang jelas.

38 **Kapasitas ruangan hilang saat diedit**
RoomsPage.tsx — nilai kapasitas dipaksa menjadi 1 atau 2 sehingga room berkapasitas 4 tersimpan kembali menjadi 1/2. Kini nilai asli capacity dan min_booking_capacity dipertahankan.

39 **Referensi properti RoomResponse tidak ada**
RoomsPage.tsx — minimum_capacity/min_capacity tidak terdefinisi pada tipe sehingga fallback tidak pernah bekerja. Kini didefinisikan pada interface.

40 **Modal Impor Produk crash saat dibuka**
InventoryPage.tsx — ImportModal merujuk productToEdit yang tidak ada di scope sehingga memunculkan ReferenceError; kode salinan mati (imageFile/handleImageChange) ikut dihapus dan pesan error upload kini tampil ke pengguna.

41 **Sinkronisasi cabang menghasilkan NaN**
useBranchSync.ts — nilai localStorage non-numerik berubah menjadi NaN dan dianggap "semua cabang". Kini dijaga Number.isFinite.

42 **Callback perubahan cabang dipanggil saat mount**
useBranchSync.ts — memicu pemuatan data ganda pada halaman yang sudah mengambil data saat mount. Kini callback pertama dilewati.

43 **Pagination menghasilkan halaman NaN/Infinity**
Pagination.tsx — itemsPerPage 0/undefined membuat totalPages Infinity dan tombol halaman NaN. Kini semua nilai dinormalisasi (safeTotalItems, safePerPage, safeCurrentPage).

44 **Nama bulan "jul" huruf kecil**
utils/date.ts — tanggal tampil "01 jul 2026". Kini "Jul".

45 **Data referensi state tidak direset antar transaksi**
POSPage.tsx — handleNewTransaction tidak mereset paymentReference, promo, dan catatan sehingga bocor ke transaksi berikutnya. Kini semua direset.

46 **Kegagalan memuat data ditampilkan sebagai "tidak ada data"**
ExpensesPage.tsx, BankDepositsPage.tsx, UserManagementPage.tsx — error request dirender sebagai empty state sehingga pengguna salah paham. Kini dibedakan dengan banner merah, pesan khusus, dan tombol "Coba lagi".

3. YANG SUDAH LOLOS / TERVERIFIKASI AMAN

Bagian berikut berisi titik pemeriksaan yang sudah berjalan benar sebelum audit dan tetap dipertahankan:

- Halaman login sudah memvalidasi email & password kosong sebelum request, menonaktifkan tombol saat loading, dan menampilkan pesan error dari server.
- BranchesPage sudah memvalidasi 10 field (nama, kode, telepon, rentang lat/lng, jam operasional, dll.) melalui validateField sebelum mengirim ke API.
- Konfirmasi dua langkah pada hapus cabang, hapus pelanggan, hapus user, hapus role, hapus ruangan, hapus banner, dan hapus staff sudah berjalan benar dengan ConfirmationModal/swal.
- Alur refund dan pembatalan booking pada BookingsPage sudah dibungkus dialog konfirmasi sebelum eksekusi.
- POSPage sudah memiliki konfirmasi pada hapus petty cash, dan tombol bayar dinonaktifkan bila uang tunai kurang atau referensi non-tunai kosong.
- Upload nota/bukti pada ExpensesPage dan BankDepositsPage sudah memvalidasi ukuran maksimal 5 MB dan tipe file JPG/PNG/PDF sebelum diunggah.
- BannersPage menampilkan layar kesalahan dengan tombol retry bila gagal memuat data, serta punya konfirmasi hapus.
- Seluruh rute admin berada di dalam ProtectedRoute sehingga tidak ada rute admin yang dapat diakses tanpa sesi.
- api.ts sudah memiliki mekanisme auto-logout global pada respon 401 (kini diperluas ke seluruh helper).
- StaffPage sudah memvalidasi format nama, telepon, email, jenis kelamin, dan urutan tanggal pada form staff.
- BranchesPage sudah memiliki tombol toggle status cabang dengan umpan balik sukses/gagal (toast).
- POSPage dan BookingsPage sudah membatasi input nominal melalui filter digit sehingga karakter non-numerik tidak dapat diketik.
- Pemeriksaan tipe data berbasis TypeScript tersedia di seluruh basis kode dan berjalan bersih untuk modul yang diaudit.
- Komponen Pagination, CurrencyInput, ConfirmationModal, dan SearchableSelect sudah memiliki default props yang aman terhadap data kosong.

Kesimpulan

Seluruh temuan pada bagian 2 telah diperbaiki dan diverifikasi ulang. Bagian 3 memastikan mekanisme validasi dan konfirmasi yang sudah ada tetap berfungsi sebagaimana mestinya.